

Manual 16 — ISO/IEC 27001 / 27002 Controlled Implementation

Controlled English master — development candidate

****Series order:**** 16

****Authoritative baseline:**** ISO/IEC 27001:2022; ISO/IEC 27001:2022/Amd 1:2024; ISO/IEC 27002:2022

****Legacy source identity:**** `77568a9e61d6769d6eb3dbbed6b131a58d60e1f1`

Publication and standards boundary

This is an independent implementation manual. It is not an ISO publication, does not reproduce protected ISO/IEC clause or control text, does not provide certification, and does not replace licensed standards. ISO/IEC 27001 is the requirements standard for an information security management system (ISMS); ISO/IEC 27002 provides control implementation guidance. Statement-of-Applicability, risk-treatment, audit, certification and conformity decisions remain context-dependent and must be supported by competent evidence and appropriate professional judgment.

Chapter 1 — ISMS purpose, governance and operating model

Define why the ISMS exists, which business outcomes it protects, and how governance converts security objectives into accountable operating decisions. Establish an executive sponsor, ISMS owner, risk owners, control owners and evidence custodians. Set a governance cadence for risk, performance, exceptions and improvement. Evidence should include the governance charter, approved security policy, role assignments, decision records and meeting outputs.

Chapter 2 — Organizational context and interested parties

Identify internal and external conditions that can affect information-security outcomes. Maintain a context record covering strategy, operating model, technology, suppliers, legal obligations, threat environment and material physical conditions. Determine relevant interested parties and the requirements that affect the ISMS. Include a documented consideration of climate-related relevance and interested-party expectations without assuming that climate concerns are automatically material to every organization.

Chapter 3 — ISMS scope and boundaries

Define a scope that is understandable, defensible and operationally real. Identify included entities, business services, locations, applications, cloud services, networks, people, suppliers and information flows. Record interfaces, dependencies and justified exclusions. Reconcile the scope to asset inventories, architecture diagrams, supplier records and legal-entity boundaries. Review the scope after material organizational, technology or regulatory change.

Chapter 4 — Leadership, policy and accountability

Executive leadership must establish direction, approve security policy, assign responsibilities and ensure the ISMS receives sufficient authority and resources. Translate leadership commitments into measurable objectives and governance decisions. Retain evidence of policy approval, executive review, resource decisions, accepted residual risks and escalation outcomes.

Chapter 5 — Roles, responsibilities and segregation

Document who owns risks, who operates controls, who reviews evidence, who approves exceptions and who performs independent assurance. Avoid incompatible combinations of access, approval and review where they create unacceptable risk. Maintain a responsibility matrix and review it when organization structure, systems or outsourcing arrangements change.

Chapter 6 — Risk-assessment methodology

Define repeatable criteria for identifying, analyzing and evaluating information-security risk. Specify assets or business services in scope, threat and vulnerability considerations, likelihood and impact scales, existing-control treatment, inherent and residual risk, risk acceptance authority and reassessment triggers. Evidence includes the approved methodology, scoring criteria, risk register and examples showing consistent application.

Chapter 7 — Risk treatment and acceptance

For each material risk, select a treatment strategy such as modify, avoid, share or accept. Link chosen actions to control objectives, accountable owners, target dates and evidence. Residual risk must be explicitly evaluated and accepted by an authorized role. Treatment plans should be tracked to closure and re-evaluated after significant changes or control failures.

Chapter 8 — Statement of Applicability governance

Use the Statement of Applicability as a governance record connecting identified risks and applicable obligations to necessary controls. Do not treat Annex A as a universal mandatory checklist. Record inclusion or exclusion reasoning, implementation status and links to supporting evidence. Reconcile changes in risk treatment to the Statement of Applicability and retain approval history.

Chapter 9 — Information-security objectives and planning

Create measurable objectives that support the policy and business context. Each objective should have an owner, metric, target, due date or review cadence and evidence source. Examples include remediation timeliness, privileged-access review completion, backup recovery performance, critical supplier assessment coverage and security-awareness outcomes.

Chapter 10 — Resources, competence and awareness

Identify the people, budget, tools, infrastructure and expertise required to operate the ISMS. Define competence requirements by role and retain evidence of training, experience, certifications or supervised qualification as appropriate. Awareness should cover policies,

expected behavior, incident reporting and role-specific obligations. Reassess resource needs when scope or risk materially changes.

Chapter 11 — Communications and documented information

Define what security information must be communicated, to whom, when and by what channel. Control documented information through ownership, versioning, approval, retention and access rules. Distinguish authoritative records from working notes. Evidence includes communication plans, controlled-document registers, approval history and retention settings.

Chapter 12 — Operational planning and control

Translate risk-treatment decisions into repeatable operational procedures. Define triggers, responsible roles, control frequency, evidence source, exception handling and escalation. Integrate controls with change management, service management, engineering and business operations so the ISMS functions as part of normal work rather than as a separate paperwork process.

Chapter 13 — Asset and information-classification governance

Maintain current inventories of information, systems, services, devices, repositories and critical dependencies. Assign ownership and classification based on business sensitivity, legal obligations and operational impact. Define handling rules for storage, transmission, sharing, retention and disposal. Reconcile asset records to cloud inventories, endpoint management, procurement and supplier systems.

Chapter 14 — Identity and access management

Define identity lifecycle processes from onboarding through role changes and termination. Apply least privilege, role-appropriate access, periodic review and timely revocation. Separate user, service and privileged identities and ensure access decisions are traceable to approved business need. Evidence includes access requests, approval records, review outputs and deprovisioning results.

Chapter 15 — Privileged access and authentication

Apply stronger governance to administrative and high-impact access. Use appropriate authentication controls, restrict standing privilege where feasible, monitor privileged activity and review emergency access. Define password, token, key and multifactor-authentication requirements according to risk. Track exceptions to an approved remediation or compensating-control plan.

Chapter 16 — Cryptography and key management

Define when encryption or other cryptographic protections are required based on risk, legal obligations and information classification. Govern algorithm and protocol choices, certificate lifecycle, key generation, storage, rotation, backup, revocation and destruction. Maintain ownership and inventory for sensitive keys and certificates and monitor expiration or weak configurations.

Chapter 17 — Physical and environmental security

Protect facilities, equipment and media according to business criticality and risk. Define physical access authorization, visitor handling, monitoring, environmental safeguards, secure areas, equipment disposal and media handling. Retain access records, review results, incident records and maintenance evidence where applicable.

Chapter 18 — Operations, logging and monitoring

Establish controlled operational procedures for systems and services. Define logging requirements, time synchronization, log protection, monitoring use cases, alert ownership, retention and escalation. Ensure logging supports security operations and investigation without collecting unnecessary data. Test that critical events are generated, retained and reviewable.

Chapter 19 — Vulnerability and configuration management

Maintain secure configuration baselines and a repeatable process for identifying, prioritizing and remediating vulnerabilities. Use risk, exploitability, exposure and business criticality to set remediation priorities. Govern exceptions with documented rationale, compensating controls, owners and expiration dates. Evidence includes scan results, patch or remediation records and exception approvals.

Chapter 20 — Secure development and change management

Integrate security into system acquisition, development and change. Define requirements for architecture review, code or configuration review, testing, dependency risk, secrets handling and release approval according to risk. Separate development, testing and production responsibilities where necessary. Link material changes to risk reassessment and evidence updates.

Chapter 21 — Supplier and third-party security

Classify suppliers by information access, service criticality, connectivity and concentration risk. Define pre-contract due diligence, contractual requirements, ongoing monitoring, incident notification, subcontractor expectations and termination procedures. Track material findings to remediation and reassess suppliers after major changes or incidents.

Chapter 22 — Cloud and shared-responsibility implementation

Document the shared-responsibility model for each cloud service and map responsibilities to actual control owners. Govern identities, configurations, encryption, logging, network controls, resilience, backup and provider dependencies. Avoid assuming provider certification eliminates customer responsibilities. Maintain evidence from both provider assurances and customer-operated controls.

Chapter 23 — Incident management and evidence

Define preparation, detection, triage, containment, eradication, recovery, communication and lessons-learned activities. Establish severity criteria, roles, escalation paths and evidence-preservation rules. Protect investigation records and maintain a chain of custody when legal or disciplinary use is possible. Feed root causes and control failures back into risk and corrective-action processes.

Chapter 24 — Business continuity and resilience

Identify information-security dependencies that support critical business services. Define recovery objectives, backup requirements, alternate processing arrangements, communications and security requirements during disruption. Test recovery scenarios, record results and remediate weaknesses. Security controls should remain proportionate during emergency operations rather than being silently disabled.

Chapter 25 — Privacy and regulatory interfaces

Identify where privacy, sectoral regulation, contractual commitments or local law affect ISMS controls. Maintain an obligations register and assign accountable owners. Avoid treating ISO/IEC 27001 as a substitute for legal analysis. Link applicable obligations to policies, risk assessments, controls, evidence and monitoring activities.

Chapter 26 — Monitoring, measurement and control effectiveness

Define metrics that show whether the ISMS and its controls operate as intended. Metrics should have owners, calculation rules, data sources, targets and thresholds. Combine quantitative indicators with targeted control testing and trend analysis. Escalate persistent underperformance and ensure metrics drive decisions rather than only reporting activity volume.

Chapter 27 — Internal audit readiness

Maintain an audit program based on scope, risk, previous findings and material change. Ensure auditors are sufficiently objective and competent for the assigned work. Define criteria, population, sampling approach, evidence expectations, findings and follow-up. Preserve workpapers so another competent reviewer can understand how conclusions were reached.

Chapter 28 — Management review

Provide leadership with a structured review of ISMS suitability, adequacy and effectiveness. Inputs should include audit results, objectives, risk status, incidents, supplier issues, resource needs, control performance, changes and improvement opportunities. Record decisions, assigned actions, owners and due dates. Follow through to closure.

Chapter 29 — Nonconformity, corrective action and remediation

When requirements or approved processes are not met, record the issue, contain immediate effects, identify root cause, determine corrective action, assign ownership and verify

effectiveness. Avoid closing findings based only on planned actions. Evidence should show implementation and validation that the issue is unlikely to recur under comparable conditions.

Chapter 30 — Continual improvement and change triggers

Use incidents, audit results, metrics, technology changes, threat intelligence, business change and lessons learned to improve the ISMS. Define formal reassessment triggers for mergers, new products, major cloud adoption, critical supplier changes, significant incidents, regulatory change and material architecture changes. Improvement decisions should be traceable to evidence and governance outcomes.

Chapter 31 — Evidence architecture, implementation paths and maturity

For each material control objective, maintain a traceable evidence chain: risk or requirement, control objective, implementation activity, accountable owner, operating frequency or trigger, evidence source, reviewer, exception path and change trigger. Distinguish design evidence from operating evidence. Use maturity indicators only to support prioritization and improvement; do not present maturity scores as certification outcomes.

Chapter 32 — Release, localization, provenance and reassessment

Freeze the controlled English source before localization. Produce es-419 and pt-BR editions only from the exact frozen English identity. Verify structural and semantic parity, then generate DOCX/PDF artifacts for all three locales. Run PDF content, rendered, accessibility and visual checks required by repository policy. Record SHA-256 identities, source lineage, workflow results and release evidence. Stage the exact verified binaries durably on `main` before catalog or release-registry promotion. Any post-hash content change requires a new candidate, new hashes and revalidation.

Controlled evidence model

Every implementation section should be traceable through the following record structure where applicable:

context/requirement → risk → control objective → implementation activity → owner → frequency/trigger → population → evidence → test/review → exception/remediation → reassessment trigger

Front-line handoff

The next gate after this English master is deterministic structural/editorial QA and exact-source freeze, followed by controlled es-419 and pt-BR localization, publication-candidate generation, rendered/accessibility review, provenance binding, durable artifact staging, exact-head release QA and final publication-state reconciliation.